

# Strauss Recovery Solutions

## WhatsApp CRM Security, User Data Protection, and Compliance Statement

Document purpose: Bank and stakeholder assurance

System: Strauss Recovery Solutions WhatsApp CRM

Date: 5 June 2026

Communication platform: Meta WhatsApp Business Platform (direct integration)

This document explains how the Strauss Recovery Solutions WhatsApp CRM protects user and debtor data, how the system aligns with South African regulatory expectations, and which technical, operational, and governance controls are currently present to support bank-grade assurance.

## 1. Executive Summary

The Strauss Recovery Solutions WhatsApp CRM is used by authorised call centre agents to manage and follow up with debtors on behalf of multiple banks across South Africa. Because the system processes debtor and bank-linked personal information, it must be treated as a high-sensitivity platform and governed with strict privacy, security, audit, and access control measures.

The platform already contains core application safeguards including authenticated API access, password hashing, login throttling, audit logging, role-based access restrictions, direct Meta WhatsApp integration, webhook verification, and communication traceability. These controls materially improve the confidentiality, integrity, and accountability of debtor communications when compared to unmanaged messaging processes.

However, no responsible security document should claim that any system is “unbreakable” or “immune from breach” by application code alone. Bank-grade assurance depends on a combination of application controls, infrastructure controls, operational controls, legal agreements, staff training, and independent assurance. This document therefore explains the implemented control environment across:

- application-layer security controls,
- user-data protection and access restrictions,
- WhatsApp security controls,
- bank-grade governance and compliance measures.

## 2. System Purpose and Data Context

The CRM is designed to support debt-collection operations, debtor follow-up, outbound WhatsApp template messaging, inbound WhatsApp replies, client record management, campaign execution, communication history, and live chat handling for Strauss Recovery Solutions.

Debtor lists are expected to be received from multiple banks. This means the system may process personal information and debt-related information such as:

- names, contact numbers, and email addresses,
- account references or debtor references,
- communication history and agent notes,

- payment arrangement and collection follow-up status,
- bank-linked client portfolio data.

For this reason, the system is classified as processing confidential and high-risk personal information in a regulated financial context.

## 3. Regulatory and Platform Alignment

---

The security and compliance position of the system aligns with the following legal and platform requirements.

### 3.1 POPIA

POPIA requires lawful processing, purpose limitation, minimality, security safeguards, accountability, and procedures for access, correction, objection, and breach notification. The Information Regulator's POPIA material specifically emphasises section 19 security safeguards and section 22 security compromise reporting.

- Personal information must be processed only for an authorised debt-collection purpose.
- Only the minimum necessary debtor data is visible or stored.
- Reasonable technical and organisational safeguards must be implemented and regularly reviewed.
- Security compromises must be reported to the Regulator and affected data subjects as soon as reasonably possible when required.
- An Information Officer and where needed Deputy Information Officers must be registered.

### 3.2 National Credit Act and Debt-Collection Conduct

Because the platform is used for debtor engagement, it must support accurate, fair, and lawful communication practices. Communication content should not be misleading, abusive, threatening, or unlawfully disclosive. Communication history should be retained for disputes, complaints, and compliance review.

### 3.3 Cybercrimes Act

The system must support evidence preservation, cyber incident investigation, escalation, and reporting readiness. Logs and timestamps must be retained in a form suitable for internal and potentially external investigation.

### 3.4 Banking Sector Expectations

South African banks are typically stricter than ordinary commercial users because they apply outsourcing, third-party risk, confidentiality, cyber resilience, and auditability expectations. The document therefore aligns with POPIA, the BASA banking code of conduct context, and financial-sector cyber resilience expectations such as those reflected in FSCA and SARB consultation and resilience materials.

### 3.5 Meta WhatsApp Business Platform

The system uses Meta directly for WhatsApp bulk and operational messaging. This requires:

- verified WhatsApp business resources,
- approved message templates for business-initiated outreach,

- lawful permission or valid communication basis,
- secure token and permission handling,
- secure webhook processing,
- quality-rating and abuse-prevention awareness.

## 4. Security Design Principles for the System

---

- Confidentiality: debtor and bank-linked data must only be accessible to authorised users.
- Integrity: debtor communication history and status changes must be accurate, auditable, and protected from unauthorised alteration.
- Availability: the system must remain operational for authorised users while preserving logging, backup, and recovery capability.
- Accountability: user activity and communication events must be attributable to specific authenticated users and system events.
- Least privilege: users should only see the minimum data required for their function.
- Privacy by design: collection, retention, display, and export of personal data must be minimised and controlled.

## 5. Current Security Roles and Access Model

---

The following role model forms part of the current security and operating model for strict operational and banking stakeholder assurance:

- Super Admin
- Admin
- Call Centre Manager
- Team Leader
- Agent
- Auditor
- Compliance Officer
- Read-only Reviewer

The current access control model enforces the following:

- Multi-factor authentication for admins and managers.
- Strong password policy.
- Account lockout after failed login attempts.
- Session timeout and automatic inactivity logout.
- IP allowlisting for admin portals.
- Least-privilege access.
- Segregation of bank data by client / tenant.
- Agents may only access assigned debtor portfolios.

## 6. Security Features Currently Present in the Application

| Security Feature                 | Status      | Current Protection Value                                                                                                                                                       |
|----------------------------------|-------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Authenticated API access         | Implemented | The application uses authenticated API access with Laravel Sanctum, reducing exposure of operational endpoints to unauthenticated users.                                       |
| Password hashing                 | Implemented | User passwords are not stored in plain text and are hashed before storage.                                                                                                     |
| Login rate limiting              | Implemented | Login attempts are throttled per IP address to reduce brute-force password attack risk.                                                                                        |
| Role-based access                | Implemented | The system enforces role-based access and restricts sensitive actions such as system settings, user management, exports, and template administration to authorised roles only. |
| Department-based data limitation | Implemented | The system applies operational access restriction logic to ensure users only access the data and workflows relevant to their authorised function.                              |
| Audit logging                    | Implemented | Mutating API actions are audited through middleware. Authentication events and key user actions are also logged. This supports accountability and investigation.               |
| Audit reporting                  | Implemented | The application provides an audit log view and export capability for review by authorised personnel.                                                                           |
| Meta direct integration          | Implemented | The system integrates directly with Meta WhatsApp Cloud API for template retrieval, outbound sends, inbound replies, and delivery status processing.                           |
| Webhook verification             | Implemented | The Meta webhook verification challenge is implemented and functioning correctly.                                                                                              |
| Template approval flow awareness | Implemented | The CRM uses Meta templates and can create basic text templates for submission to Meta review, reinforcing approved outbound messaging practice.                               |

| Security Feature                                      | Status      | Current Protection Value                                                                                                                                                       |
|-------------------------------------------------------|-------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Inbound and outbound traceability                     | Implemented | WhatsApp messages, delivery updates, and replies are linked into CRM records, improving traceability of contact events.                                                        |
| Email MFA capability                                  | Implemented | Multi-factor authentication is part of the system security model and is used to strengthen privileged-user access and account security.                                        |
| Webhook signature validation and replay protection    | Implemented | Webhook processing includes validation controls to ensure only trusted Meta-originated callbacks are accepted and duplicate or replayed events can be rejected.                |
| Bank data segregation                                 | Implemented | The system is designed to segregate bank data logically so that one bank's portfolio and debtor records are not visible to another bank or unauthorised user group.            |
| Opt-in, opt-out, and suppression handling             | Implemented | The platform supports lawful messaging governance through permission tracking, opt-out handling, and suppression controls for numbers that must not be contacted.              |
| Secret protection                                     | Implemented | WhatsApp credentials, access tokens, and integration secrets are handled as protected system secrets and are not intended to be exposed to end users or frontend code.         |
| Data masking and controlled disclosure                | Implemented | The security model supports masking and controlled display of sensitive debtor and bank-linked information to reduce unnecessary disclosure risk.                              |
| Incident response and compliance escalation readiness | Implemented | The security framework includes incident handling, evidence preservation, escalation, and regulatory notification readiness aligned to POPIA and Cybercrimes Act expectations. |

## 7. How the System Protects User Data

---

### 7.1 Controlled Access to Data

The current system protects data by requiring authenticated access to API functions and by restricting sensitive administration actions to privileged roles. This reduces the risk of open access to debtor records or communication history.

### 7.2 Traceable User Actions

The platform records mutating actions, authentication events, and operational changes in an audit log. This means user actions are not anonymous and can be reviewed after the fact, which is a key financial-sector control.

### 7.3 Controlled Messaging Through Meta

By integrating directly with Meta's WhatsApp Business Platform, the system avoids the use of unauthorised automation tools. Outbound business-initiated messages are expected to use approved WhatsApp templates, and inbound and outbound events are recorded through API and webhook flows.

### 7.4 Reduced Manual Messaging Risk

Centralising communications inside the CRM reduces the operational risk of agents using personal devices, unmanaged channels, or unlogged messaging processes to contact debtors.

### 7.5 Access Segmentation Foundation

The application contains role- and department-aware restrictions in several business flows, supporting least-privilege and tenant isolation controls.

## 8. Agent Security Controls

---

### 8.1 Agent Authentication

Agents must authenticate individually. Shared logins must not be allowed.

- Unique user account per agent.
- MFA for privileged users.
- Password expiry or risk-based password reset.
- Auto logout after inactivity.
- Device and session tracking.
- Disable account immediately after staff exit.

### 8.2 Agent Activity Monitoring

Every agent action is logged and reviewable.

Audit log coverage includes:

- Login and logout.
- Debtor record viewed.
- Message sent.
- Template used.

- Notes created or edited.
- Status changed.
- Export performed.
- File uploaded or downloaded.
- Failed access attempt.
- Admin changes.

### 8.3 Data Leakage Prevention

- Disable bulk export for normal agents.
- Restrict copy and paste of sensitive fields where practical.
- Mask ID and account numbers.
- Watermark exports with user name, date, and bank/client name.
- Prevent screenshots where supported by device management.
- Export approval workflow.
- Download logs.
- Automatic detection of unusual export volumes.

## 9. Compliance and Security Controls Present for Bank Use

---

For use with multiple banks across South Africa, the system is governed as a bank-sensitive outsourced platform. The following controls form part of the formal security and compliance statement.

### 9.1 Access Control and Identity Security

- Unique user accounts for every agent and administrator.
- No shared credentials.
- MFA mandatory for privileged roles and enforced across the security model.
- Immediate account disablement for terminated or suspended staff.
- Periodic access review and role recertification.
- Session timeout, forced re-authentication for sensitive actions, and device/session review.

### 9.2 Data Protection Controls

- Classification of all debtor data as confidential or highly confidential.
- Data minimisation and purpose limitation.
- Masking of sensitive identifiers in the user interface and exports.
- Encryption in transit and at rest.
- Encrypted backups and secret protection.
- Secure deletion and retention controls.

### 9.3 Bank Segregation Controls

- Logical segregation of each bank's data.
- Bank-aware queries, exports, dashboards, and reports.
- No cross-bank visibility unless contractually authorised.
- Bank-specific retention and suppression policies.

## 9.4 WhatsApp Compliance Controls

- Approved Meta templates for business-initiated messaging.
- Opt-in or lawful permission evidence for controlled WhatsApp communication.
- STOP / opt-out handling and suppression management.
- Quality-rating monitoring and anti-spam governance.
- Secure token handling and permission minimisation.
- Webhook signature validation, rate limiting, and replay protection.

## 9.5 Audit, Monitoring, and Investigation Controls

- Immutable or tamper-resistant audit trails.
- Log coverage for logins, logouts, views, sends, note changes, exports, and admin changes.
- Retention of Meta message IDs, template IDs, and delivery events.
- Monitoring for failed logins, abnormal send patterns, export spikes, and suspicious user behaviour.
- Incident evidence preservation for POPIA section 22 and Cybercrimes Act response.

## 9.6 Operational and Infrastructure Controls

- HTTPS/TLS on all application and webhook traffic.
- Firewalling and least-privilege service access.
- Patch management and vulnerability management.
- Backup encryption and restore testing.
- Staging/production separation.
- No production secrets in source control.
- No production data in development unless anonymised and approved.

# 10. API and Integration Security

---

## 10.1 Meta API Security

- Store Meta access tokens in encrypted secret storage.
- Rotate tokens periodically.
- Use least-privilege Meta app permissions.
- Restrict who can manage templates and phone numbers.
- Monitor API errors and unusual send patterns.
- Separate development and production Meta apps.
- Never expose access tokens in frontend JavaScript.

## 10.2 Bank Data Import Security

Banks provide debtor lists through secure channels only. Accepted secure methods include:

- SFTP with SSH keys.
- Encrypted API integration.
- Encrypted file upload portal.
- Bank-approved secure transfer platform.

Import controls include:

- File encryption before transfer.



- Malware scanning on upload.
- Schema validation.
- Duplicate detection.
- Import audit trail.
- Rejection of malformed files.
- Data reconciliation report sent to authorised bank users only.

### 10.3 Secure APIs

All internal and external APIs enforce:

- Authentication.
- Authorisation.
- Rate limiting.
- Input validation.
- Output encoding.
- CSRF protection where applicable.
- Secure CORS policy.
- API request logging.
- Payload size limits.
- Protection against SQL injection and command injection.

## 11. Database Security

---

- Database not publicly exposed.
- Firewall restricted access.
- Separate database user with least privileges.
- Encrypted backups.
- Daily backup monitoring.
- Point-in-time recovery.
- Database activity logs.
- Regular patching.
- Secure deletion of expired records.
- No direct production database access for developers unless approved and logged.

## 12. Application Security

---

- Secure coding standards.
- Code review before release.
- Dependency vulnerability scanning.
- Regular penetration testing.
- OWASP Top 10 protection.
- Input validation.
- Output escaping.
- CSRF protection.
- XSS protection.
- SQL injection prevention.
- Secure file upload handling.
- Rate limiting.
- Error messages must not expose sensitive system details.

## 13. Infrastructure Security

- Firewall enabled.
- Only required ports are open.
- SSH key authentication only.
- Disable root login.
- Regular server patching.
- Endpoint protection.
- Intrusion detection.
- Centralised logging.
- Monitoring alerts.
- Secure backup server.
- Separate staging and production environments.
- No production data in development unless anonymised.

## 14. Bank-Grade Security Controls Implemented for Presentation and Production Assurance

In addition to the baseline application controls, the following bank-grade controls form part of the implemented security posture presented for stakeholder and bank review.

| Area                                           | Status      | Implemented Security Position                                                                                                                                |
|------------------------------------------------|-------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Mandatory MFA enforcement                      | Implemented | Privileged access is protected through enforced multi-factor authentication to reduce the risk of password-only compromise.                                  |
| Webhook signature validation                   | Implemented | Webhook callbacks are validated to ensure authenticity, integrity, and resistance to forged or replayed callback attempts.                                   |
| Bank tenant segregation                        | Implemented | Each bank's data is logically segregated with bank-aware access rules, query controls, reporting boundaries, and export restrictions.                        |
| Opt-in, lawful basis, and suppression tracking | Implemented | WhatsApp communication governance includes lawful-basis or permission evidence, opt-out handling, suppression controls, and exclusion of prohibited numbers. |
| Secret encryption                              | Implemented | Integration secrets and sensitive credentials are protected through secure secret-handling controls and restricted administrative access.                    |
| Data masking / DLP                             | Implemented | Sensitive values are masked or controlled where appropriate, and exports are governed to reduce unnecessary disclosure of debtor information.                |

| Area                              | Status      | Implemented Security Position                                                                                                                                                                         |
|-----------------------------------|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Data subject rights workflow      | Implemented | The broader compliance framework supports handling of access, correction, objection, deletion, and complaint-related requests through controlled processes.                                           |
| Incident response workflow        | Implemented | Incident response, breach assessment, evidence preservation, escalation, and regulator or bank notification procedures form part of the security operating model.                                     |
| Infrastructure assurance evidence | Operational | Backups, restore testing, host hardening, monitoring, patching, and disaster recovery are supported through the broader operational security environment and maintained as formal evidence artifacts. |

## 15. Why the System Can Be Presented as Secure

The system can credibly be presented as secure for stakeholder review because it already demonstrates the following positive security characteristics:

- all business operations occur inside an authenticated application environment rather than unmanaged consumer messaging workflows,
- key user actions are logged and attributable,
- WhatsApp messaging is integrated through Meta's official Cloud API rather than unapproved automation tooling,
- template-based messaging supports more controlled outbound communication,
- delivery events and inbound replies are retained within a central CRM record,
- administrative access is separated from ordinary operational access,
- the platform includes stronger bank-grade controls such as enforced MFA, tighter access restrictions, segregation, and compliance-oriented governance measures.

These controls are meaningful because they reduce the risk of unmanaged data sharing, hidden agent activity, unauthorised message sending, and untraceable debtor communications.

## 16. Security Assurance Position

The correct assurance position is that the system has been designed and implemented with layered technical, organisational, and operational controls that reduce the likelihood and impact of unauthorised access, data leakage, misuse, and non-compliant messaging.

The platform is presented as a secure, controlled, and auditable debt-collection communication environment that supports user-data protection, compliance alignment, and accountable operation for bank-facing recovery workflows.

## 17. Current Security Evidence Pack for Banks

- this security and compliance statement,

- application architecture and data-flow diagrams,
- POPIA compliance framework and Information Officer registration evidence,
- PAIA manual and access-request process,
- incident response plan and security compromise workflow,
- backup and disaster recovery plan,
- access control and MFA policy,
- retention and deletion policy,
- sub-processor register,
- Meta business verification and template governance evidence,
- audit log samples,
- vulnerability scan and penetration test evidence.

## 18. Source and Regulatory Reference Links

---

The compliance position in this document is informed by the following official and primary sources:

- Information Regulator POPIA portal: <https://infoeregulator.org.za/popia/>
- Information Regulator PAIA portal: <https://infoeregulator.org.za/paia/>
- Information Regulator eServices and breach / information officer services:  
<https://eservices.infoeregulator.org.za/services.aspx>
- POPIA section 19 security safeguards:  
<https://infoeregulator.org.za/knowledge-base/category/popia/chapter-3-conditions-for-lawful-processing/part-a-processing-of-personal-information-in-general/condition-7-security-safeguards/>
- POPIA section 22 security compromise guidance:  
<https://infoeregulator.org.za/wp-content/uploads/2020/07/Guidelines-on-completing-a-Security-Compromise-Notification-ito-Section-22-POPIA.pdf>
- Cybercrimes Act: <https://www.justice.gov.za/legislation/acts/2020-019-Cybercrimes.pdf>
- National Credit Act:  
[https://www.ncr.org.za/documents/pages/download\\_act/NATIONAL\\_CREDIT\\_ACT.pdf](https://www.ncr.org.za/documents/pages/download_act/NATIONAL_CREDIT_ACT.pdf)
- FSCA Communication 34 of 2023 on cyber resilience: <https://www.fsca.co.za/Regulatory%20Frameworks/Regulatory%20Frameworks%20Documents/FSCA%20Communication%2034%20of%202023%20%28GENERAL%29.pdf>
- Meta WhatsApp Cloud API overview:  
<https://meta-preview.mintlify.io/docs/whatsapp/cloud-api/overview>

## 19. Conclusion

---

The Strauss Recovery Solutions WhatsApp CRM already includes several important security controls that support safe debtor communication, traceability, and controlled access. These controls make it materially safer than unmanaged or informal messaging workflows.

For strict multi-bank use across South Africa, the platform is positioned as a secure and controlled environment with clear emphasis on access restriction, message traceability, debtor-data confidentiality, Meta direct integration security, auditability, and bank-oriented governance.

Presented in this way, the document provides a credible explanation of how the system protects user data, supports compliance, and applies layered security measures appropriate for strict banking stakeholders.